

CISSP Printable Practice Exam 12 - Domain 4 - Communication and Network Security

Practice Exam 02 - Domain 4

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP2-060)

Scenario: A security reviewer finds that an internally developed file-transfer service listens on TCP port 443. The network team considers the traffic safe because that port is commonly associated with HTTPS, but the service does not implement HTTP or TLS.

What is the MOST accurate conclusion?

- A. The port number alone does not establish the application protocol or provide encryption.
- B. Any service using TCP port 443 automatically receives transport encryption.
- C. The service is secure if a stateful firewall permits the connection.
- D. Changing the service to a high-numbered port would provide confidentiality.

Question 2 (CISSP2-061)

Scenario: Employees on an IPv6-enabled office LAN intermittently receive an unauthorized default gateway after a compromised workstation begins advertising itself as a router. Existing perimeter filtering does not stop the local messages.

Which control would BEST mitigate this attack at the relevant location?

- A. Apply IPv6 router advertisement filtering or guard functions on access switches.
- B. Block outbound HTTPS at the Internet firewall.
- C. Increase the lease duration on the IPv4 address server.
- D. Configure public address translation for all internal IPv6 hosts.

Question 3 (CISSP2-062)

Scenario: A design studio plans to carry ordinary user data and latency-sensitive storage traffic over shared high-speed network links. A disruption affecting user traffic must not be allowed to compromise storage availability or expose storage flows.

Which design is the BEST response?

- A. Use logical separation, tightly restricted flow policy, capacity planning, and traffic-class monitoring.
- B. Place both traffic types in one unrestricted broadcast domain to simplify troubleshooting.
- C. Rely only on higher link speed because congestion and access control are equivalent risks.
- D. Permit every endpoint to initiate storage sessions so failover remains flexible.

Question 4 (CISSP2-063)

Scenario: An enterprise receives fragmented IP traffic whose initial fragment contains transport information while later fragments do not. Different security devices make inconsistent permit decisions, creating an opportunity to evade policy.

What is the MOST effective architectural response?

- A. Normalize or reassemble fragments at a controlled boundary before applying a consistent inspection policy.
- B. Approve later fragments because they do not contain a visible destination port.
- C. Inspect only Ethernet source addresses for all fragmented Internet traffic.
- D. Increase application session timeouts so every fragment remains active longer.

Question 5 (CISSP2-064)

Which TWO statements about layered communication are accurate? Select 2 of the 5 options below.

- A. A router forwarding an ordinary IP packet can make a path decision without interpreting its application payload.
- B. A TCP destination port identifies the physical switch port where a cable is attached.
- C. Link-layer headers can change at each routed hop while the end-to-end IP packet is forwarded.
- D. Encapsulation guarantees that every intermediate device can read all inner-layer data.
- E. A UDP header supplies the reliability and ordered delivery guarantees of TCP.

Question 6 (CISSP2-065)

Scenario: A warehouse separates handheld scanners from administrative workstations with VLANs. An audit finds that user-facing switch ports negotiate trunking dynamically and accept traffic tagged for multiple VLANs.

Which remediation should be implemented FIRST?

- A. Configure user-facing ports statically as access ports and restrict trunking to explicitly approved links.
- B. Expand the administrative VLAN so it includes every warehouse endpoint.
- C. Enable dynamic trunk negotiation on all switch ports for consistency.
- D. Move inter-VLAN filtering from the gateway to each handheld application.

Question 7 (CISSP2-066)

Scenario: A corporate campus detects a wireless network using a name similar to the employee network. The signal appears to originate inside the building, but the device is absent from the approved inventory.

What is the BEST next action for the security team?

- A. Use authorized wireless monitoring and switch records to locate, validate, and isolate the device.
- B. Increase the power of approved access points until the other signal is obscured.
- C. Rename the employee network and treat the unknown device as resolved.
- D. Connect to the unknown network with production credentials to identify its owner.

Question 8 (CISSP2-067)

Scenario: A transportation operator relies on a software-defined network for operational communications. Several forwarding devices may temporarily lose contact with the controller, but critical approved flows must remain available without opening broad new paths.

Which design decision BEST addresses this condition?

- A. Define tested local failover rules that preserve only essential authorized flows until controller service returns.
- B. Configure the devices to permit all traffic whenever controller communication fails.
- C. Erase every forwarding rule immediately, including those needed for safety operations.
- D. Allow endpoints to modify forwarding policy during the outage.

Question 9 (CISSP2-068)

Scenario: A global nonprofit has separate cloud networks for finance, analytics, and development. Ad hoc peering has produced unintended transitive routes, and the organization needs one auditable point for approving inter-network communication.

Which architecture BEST meets the objective?

- A. A controlled hub-and-spoke design with explicit route and inspection policy between segments
- B. Full-mesh peering with every route automatically propagated
- C. One flat cloud subnet shared by all business functions
- D. Independent Internet gateways used as the normal path between internal networks

Question 10 (CISSP2-069)

Scenario: A field organization uses enterprise wireless authentication at temporary offices. Users have previously accepted prompts from unrecognized authentication servers, and attackers can imitate the approved network name.

Which TWO controls BEST reduce the risk? Select 2 of the 5 options below.

- A. Configure managed clients to validate the authentication server's certificate and expected identity.
- B. Treat a matching network name as sufficient proof that an access point is authorized.
- C. Use wireless monitoring to identify access points that do not match the approved inventory.
- D. Instruct users to approve any certificate prompt when signal strength is high.
- E. Publish the employee authentication secret for use at every temporary office.

Question 11 (CISSP2-070)

Scenario: A ticketing service remains reachable, but its perimeter firewall exhausts its state table during a surge of incomplete connection attempts. Adding application servers does not improve the condition.

Which response would MOST directly address the bottleneck?

- A. Apply connection-rate protections and capacity controls at or before the stateful boundary.
- B. Add storage capacity to the application database.
- C. Extend the timeout for every incomplete connection.
- D. Enable unrestricted inbound access on an alternate firewall interface.

Question 12 (CISSP2-071)

Scenario: A mining company learns that a device connected to a remote network segment can advertise unauthorized routes to an infrastructure router. Only designated neighboring routers should participate in route exchange.

What should the network security architect recommend?

- A. Authenticate routing peers, restrict permitted neighbors, and filter accepted route advertisements.
- B. Accept routes from any adjacent device and rely on shortest-path selection.
- C. Disable logging of routing changes to reduce control-plane load.
- D. Allow user workstations to override routes during connectivity problems.

Question 13 (CISSP2-072)

Scenario: A laboratory must run a high-bandwidth network link between two controlled buildings through a shared utility corridor. The security objective is to reduce

electromagnetic interception risk and detect physical tampering.

Which design is MOST appropriate?

- A. Use fiber in protected conduit with controlled termination points and tamper monitoring.
- B. Use unshielded copper laid openly because higher bandwidth prevents interception.
- C. Use an unencrypted public wireless bridge with a hidden network name.
- D. Place repeaters throughout the corridor with publicly accessible management ports.

Question 14 (CISSP2-073)

Scenario: A benefits administrator wants external clients to reach a web application without exposing origin server addresses. It also needs centralized request filtering and connection termination before traffic reaches the application tier.

Which network component BEST fulfills this role?

- A. A reverse proxy positioned in front of the origin servers
- B. A forward proxy configured on employee browsers
- C. An unmanaged Layer 2 hub beside each server
- D. A routing protocol neighbor on the internal core

Question 15 (CISSP2-074)

Scenario: An endpoint protection platform identifies a compromised laptop that is actively scanning internal systems. The response team must stop lateral communication while preserving limited connectivity needed to collect evidence remotely.

Which TWO actions BEST satisfy the requirement? Select 2 of the 5 options below.

- A. Dynamically place the laptop in a restricted containment network.
- B. Allow the laptop unrestricted access until the investigation is complete.
- C. Permit only explicitly required response and evidence-collection connections.
- D. Disable monitoring alerts so the analyst can work without interruption.
- E. Move sensitive servers into the laptop's current segment.

Question 16 (CISSP2-075)

Scenario: A defense supplier allows remote employees to connect to sensitive internal applications while their devices also maintain direct Internet access. Security policy requires corporate inspection of remote traffic and prohibits a device from bridging trusted and untrusted paths.

Which configuration BEST aligns with the policy?

- A. Disable split tunneling and route remote-device traffic through the controlled corporate security path.
- B. Enable split tunneling for every destination to reduce corporate bandwidth use.
- C. Allow users to choose the routing mode separately for each session.
- D. Replace the encrypted remote channel with direct access to internal applications.

Question 17 (CISSP2-076)

Scenario: Employees connecting to an internal payroll portal receive a certificate-name mismatch warning after a network change. The site is reachable, but the security team has not yet confirmed whether the endpoint is legitimate.

What should users be instructed to do?

- A. Stop the connection and report the warning so the endpoint and certificate can be validated.

- B. Bypass the warning because encryption remains trustworthy without server authentication.
- C. Enter credentials first and verify the server identity afterward.
- D. Disable certificate validation for all internal web services.

Question 18 (CISSP2-077)

Scenario: An insurance company transfers regulated records from its private cloud network to a managed cloud service. The security architect wants traffic to avoid public addressing, follow a defined private route, and be restricted to the approved service endpoint.

Which approach BEST meets the objective?

- A. Use provider-supported private service connectivity with endpoint-specific routing and access policy.
- B. Assign public addresses to every workload and rely on obscurity of the service URL.
- C. Send records through an open Internet relay to simplify routing.
- D. Permit all cloud destinations so service endpoint changes cannot interrupt transfers.

Question 19 (CISSP2-078)

Scenario: A pharmaceutical distributor will exchange automated inventory messages with a business partner. The channel must authenticate both endpoints, limit the partner to one service, and support prompt termination without redesigning the internal network.

What is the BEST design?

- A. Terminate mutually authenticated connectivity in a controlled partner zone and permit only the required service flow.
- B. Extend the internal user network to the partner and rely on application naming conventions.
- C. Use one permanent shared credential for all current and future partners.
- D. Allow the partner to select internal routes dynamically after connecting.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP2-060) - Correct: A

A port number is a convention used to identify an expected service, not proof of the protocol or its security properties. Encryption must be implemented and validated by the communicating systems. Firewall permission, port selection, and use of an ephemeral-looking number do not create confidentiality.

Question 2 (CISSP2-061) - Correct: A

The malicious router advertisement occurs on the local IPv6 segment, so an access-layer guard that permits such messages only from trusted ports directly addresses it. Perimeter HTTPS rules and IPv4 lease settings operate elsewhere, while address translation does not validate local IPv6 control messages.

Question 3 (CISSP2-062) - Correct: A

Converged infrastructure requires both security separation and engineering for predictable service. Logical segmentation, least-privilege flows, capacity controls, and monitoring address confidentiality and availability together. A flat network, bandwidth alone, or unrestricted initiation leaves important threats untreated.

Question 4 (CISSP2-063) - Correct: A

Controlled normalization or reassembly gives the enforcement point sufficient context to apply one coherent policy and detect evasive fragmentation. Automatically permitting incomplete fragments creates a gap, link-layer addresses do not supply the missing Internet transport context, and longer timeouts do not resolve inconsistent inspection.

Question 5 (CISSP2-064) - Correct: A, C

Routers can forward using network-layer information, and link-layer framing is rebuilt as a packet crosses routed links. TCP ports identify transport endpoints rather than physical jacks, encapsulation may hide inner content, and UDP does not provide TCP's ordered, reliable delivery behavior.

Question 6 (CISSP2-065) - Correct: A

Static access-port configuration and explicitly controlled trunks prevent endpoints from negotiating unintended VLAN access. Expanding the sensitive VLAN or enabling negotiation broadly weakens segmentation, while application controls do not replace enforcement of the network boundary.

Question 7 (CISSP2-066) - Correct: A

Correlating radio observations with wired-network records supports safe identification and containment of a rogue device. Raising transmit power or renaming the network does not remove the threat, and testing it with production credentials could disclose those credentials to an attacker.

Question 8 (CISSP2-067) - Correct: A

Predefined, tested failover behavior can maintain critical service while limiting the authorization scope during a control-plane outage. Permitting everything fails open, deleting every rule sacrifices required availability, and endpoint-controlled policy creates an untrusted management path.

Question 9 (CISSP2-068) - Correct: A

A governed hub-and-spoke model centralizes inter-segment routing and inspection while making approved paths auditable. Full-mesh propagation and a flat subnet increase unintended

reachability, while using public gateways for routine internal communication adds exposure and does not provide the requested central control.

Question 10 (CISSP2-069) - Correct: A, C

Server-certificate validation prevents clients from trusting an imitation authentication service, and wireless monitoring helps detect unauthorized infrastructure. A network name and signal strength do not establish identity, while publishing or casually approving authentication material defeats the trust model.

Question 11 (CISSP2-070) - Correct: A

The constrained resource is the firewall's connection state, so rate protections, upstream filtering, and appropriate state capacity target the actual failure point. Database storage is unrelated, longer incomplete-session timeouts worsen consumption, and an unrestricted alternate path bypasses protection.

Question 12 (CISSP2-071) - Correct: A

Peer authentication, neighbor restrictions, and route filters provide layered control over who may participate and what routes may be learned. Path selection alone does not establish trust, suppressing logs reduces detection, and endpoint overrides would expand control-plane authority to untrusted systems.

Question 13 (CISSP2-072) - Correct: A

Fiber does not radiate signals like copper, and protected conduit, controlled endpoints, and monitoring address physical interference. Open copper and unsecured wireless increase interception exposure, while accessible repeaters add vulnerable components rather than protecting the link.

Question 14 (CISSP2-073) - Correct: A

A reverse proxy accepts inbound client connections on behalf of origin servers and can centralize filtering and termination while hiding origin addresses. A forward proxy represents outbound clients, and neither a hub nor a routing neighbor performs the required application-intermediary function.

Question 15 (CISSP2-074) - Correct: A, C

Network containment limits lateral movement, while narrowly authorized response connections preserve the evidence-collection path. Unrestricted access leaves the attack active, disabling alerts reduces visibility, and relocating sensitive systems toward the compromised host increases exposure.

Question 16 (CISSP2-075) - Correct: A

Routing remote traffic through the controlled enterprise path supports required inspection and avoids simultaneous trusted and untrusted connectivity. Split tunneling conflicts with the stated policy, user-selected routing weakens consistent enforcement, and direct access removes the protected channel.

Question 17 (CISSP2-076) - Correct: A

A name mismatch means the client has not established that the certificate represents the intended server, so the safe response is to stop and validate the endpoint. Encryption without authenticated identity can terminate at an impostor, and entering credentials or broadly disabling validation increases that risk.

Question 18 (CISSP2-077) - Correct: A

Private service connectivity keeps the network path off public addressing and can combine

explicit routing with endpoint policy. Public workloads, open relays, and unrestricted destinations expand exposure and fail to enforce the approved communication path.

Question 19 (CISSP2-078) - Correct: A

A controlled partner zone, mutual endpoint authentication, and a narrowly permitted service path provide strong identity, least privilege, and a clear revocation point. Extending an internal network, sharing credentials broadly, or delegating route control creates excessive and poorly attributable access.